



Dossier de sécurité et de conformité

Protection des renseignements personnels · Conformité Loi 25 · Sécurité applicative

Document de référence — Juin 2026 · arriereplanrh.com

1. Conformité à la Loi 25 (Québec)

Consentement explicite

- À la première connexion, chaque utilisateur doit lire et accepter la politique de confidentialité avant d'accéder à la plateforme (consentement horodaté et conservé au dossier).

Droit à l'oubli (anonymisation)

- Anonymisation complète d'un ancien employé en un clic : nom remplacé par un identifiant neutre, courriel désactivé, compte suspendu, notes effacées, pointages et licences anonymisés.
- Chaque anonymisation est elle-même inscrite au journal d'audit avec le détail des données touchées.

Journal d'audit inaltérable

- Plus de 140 points d'audit : chaque action sensible (connexion, modification de dossier, export de paie, changement de politique de sécurité, anonymisation, consultation de documents...) est enregistrée avec l'auteur, son rôle, la date et le détail de l'action.
- Permet de démontrer en tout temps *qui a fait quoi, quand* — exigence centrale de la Loi 25 en cas d'incident.

Minimisation et cloisonnement des données

- Chaque pharmacie ne voit que ses propres données (cloisonnement strict par organisation).
- Les employés n'accèdent qu'à leurs propres renseignements (libre-service « Mon espace »).

Traçabilité des incidents

- Détection des connexions depuis une nouvelle adresse IP avec alerte automatique — identification rapide d'un accès non autorisé (obligation de notification des incidents de confidentialité).

2. Sécurité des comptes et de l'authentification

Mots de passe hachés (bcrypt)	Hachés avec bcrypt (algorithme de hachage renforcé) — jamais stockés en clair ; même l'équipe technique ne peut pas les lire.
Vérification en 2 étapes (MFA — authentification multifacteur)	Codes TOTP (mot de passe à usage unique basé sur le temps) compatibles Google Authenticator ; secrets MFA chiffrés en base de données.
MFA imposable	L'administrateur peut exiger la MFA pour tous les comptes de la pharmacie.
Politique de mot de passe configurable	Longueur minimale, majuscule / minuscule / chiffre / caractère spécial, expiration (90 j, 180 j ou 1 an) avec renouvellement forcé.
Sessions à durée limitée	Jetons JWT (JSON Web Token) expirant après 24 heures — reconnexion obligatoire.

Réinitialisation sécurisée	Code à usage unique envoyé par courriel, valide 15 minutes, maximum 5 tentatives, haché en base.
Alertes de connexion suspecte	Courriel automatique lors d'une connexion depuis une nouvelle adresse IP (Internet Protocol — l'adresse réseau de l'appareil).
Borne de pointage protégée	NIP (numéro d'identification personnel) à 4 chiffres haché avec SHA-256 (Secure Hash Algorithm — algorithme de hachage sécurisé) et un poivre secret ; verrouillage temporaire après plusieurs NIP invalides (anti-force brute).

3. Chiffrement des données

- **En transit** : toutes les communications passent par HTTPS/TLS (Transport Layer Security — protocole de chiffrement des communications entre le navigateur et le serveur).
- **Au repos** : les documents sensibles (certificats de licences professionnelles de l'OPQ — Ordre des pharmaciens du Québec) sont chiffrés avec une clé Fernet basée sur AES (Advanced Encryption Standard — norme de chiffrement avancé) avant stockage — un accès direct aux fichiers ne révèle rien.
- **Secrets MFA** : chiffrés avec la même infrastructure de clés.
- **Clés et identifiants** : aucun secret n'est inscrit dans le code source ; tout est stocké dans des variables d'environnement sur le serveur uniquement.

4. Contrôle d'accès

- **Rôles hiérarchiques** : superadmin, administrateur, gestionnaire, employé — chacun ne voit que ce qui le concerne.
- **Accès par module personnalisable** : l'administrateur contrôle précisément quels modules chaque rôle (ou chaque personne) peut consulter.
- **Champs sensibles filtrés** : taux horaires, NIP et données RH ne sont jamais renvoyés aux employés non autorisés.

5. GitHub — sauvegarde et intégrité du code

Important : GitHub n'héberge que le code source, jamais les données personnelles. Le code ne contient aucun renseignement personnel ni aucun secret.

- **Dépôt privé** : code visible uniquement par les collaborateurs autorisés.
- **Historique complet et inaltérable** : chaque modification du code est tracée (qui, quand, quoi) — retour possible à toute version antérieure.
- **Chiffrement** au repos et en transit ; détection automatique de secrets accidentellement exposés.
- **Standard de l'industrie** : utilisé par les institutions financières, gouvernements et systèmes de santé (propriété de Microsoft).
- **Continuité d'affaires** : en cas de panne de l'hébergeur, l'application peut être redéployée ailleurs en quelques heures à partir du dépôt.

6. Hébergement des données

- **Situation actuelle** : application déployée sur une infrastructure infonuagique gérée (conteneurs isolés, HTTPS, base MongoDB dédiée).
- **Ce que la Loi 25 exige** : les renseignements personnels peuvent être hébergés hors Québec à condition qu'une évaluation des facteurs relatifs à la vie privée (ÉFVP) démontre une protection adéquate.

Option renforcée planifiée — hébergement 100 % québécois

- OVHcloud (Beauharnois), AWS ou Google Cloud (région Montréal) avec MongoDB Atlas région Montréal.
- Avantage : les données ne quittent jamais le Québec → aucune ÉFVP de transfert requise, conformité simplifiée, argument de confiance pour les pharmacies clientes.
- Sauvegardes automatiques et chiffrement géré inclus avec MongoDB Atlas.

7. Mesures complémentaires

- Signatures électroniques conservées avec horodatage au dossier de l'employé.
- Suivi des licences professionnelles (OPQ) avec certificats chiffrés et alertes d'expiration.
- Séparation des environnements : développement distinct de la production — aucun test sur les données réelles.
- Gestion des départs : suspension immédiate du compte et anonymisation possible à la fin de l'emploi.

8. Tests de durcissement de la base de données — résultats

Tests exécutés le 19 août 2026 selon la liste de vérification de durcissement MongoDB (pare-feu, liaison d'adresses IP, authentification, balayage externe).

Test	Méthode	Résultat
Balayage externe des ports base de données (« test ultime »)	Tentatives de connexion TCP depuis l'extérieur du réseau vers les ports 27017, 27018 et 27019 de la production (arriereplanrh.com) et de l'environnement de développement.	CONFORME — Connexion refusée sur tous les ports base de données. Seul le port 443 (HTTPS) répond.
Point d'entrée unique	Vérification des ports exposés publiquement.	CONFORME — L'application n'est joignable que par HTTPS (443) ; la base de données n'a aucune adresse publique.
Isolation réseau (équivalent pare-feu UFW)	La base MongoDB vit dans un conteneur isolé (Kubernetes) : seul le serveur d'application du même conteneur peut lui parler.	CONFORME — Équivalent moderne de la règle « ALLOW FROM [IP application] » exigée sur un serveur autonome.
Liaison d'adresses (bindIp)	Inspection du fichier de configuration mongod.conf.	VÉRIFIÉ — bindIp : 127.0.0.1 (connexions locales seulement) dans la configuration ; l'exposition externe est bloquée au niveau réseau (confirmé par le balayage).
Authentification MongoDB (authorization)	Vérification de la configuration de sécurité du serveur de base de données.	PLANIFIÉ — Non requise dans l'environnement géré actuel (base inaccessible de l'extérieur : contrôle compensatoire). Sera imposée d'office lors de la migration vers MongoDB Atlas région Montréal (authentification + TLS + liste blanche d'IP obligatoires).

Conclusion des tests : le critère décisif — l'injoignabilité de la base de données depuis Internet — est démontré sur les deux environnements. Les recommandations propres aux serveurs autonomes (UFW, bindIp réseau privé) sont couvertes par des contrôles équivalents de l'infrastructure conteneurisée.

9. Encadrement de l'intelligence artificielle (IA)

Arrière Plan utilise l'IA pour générer les horaires, les formations et certaines analyses. Voici pourquoi cette IA ne peut pas prendre vos renseignements sensibles ni en faire un usage non autorisé :

- **Minimisation des données** : l'IA ne reçoit que le strict nécessaire à chaque tâche (noms, postes, disponibilités, budgets). Elle ne reçoit jamais de mots de passe, de NIP (numéros d'identification personnels), de documents signés ni de renseignements médicaux.
- **Aucun accès direct** : l'IA n'a aucun accès à la base de données. Elle reçoit une demande ponctuelle, renvoie une proposition, puis l'échange se termine — sans mémoire persistante de vos données.
- **Aucun entraînement sur vos données** : les modèles sont utilisés par API professionnelle (interface de programmation d'applications), dont les conditions d'utilisation excluent l'usage des données transmises pour entraîner les modèles.
- **Transit chiffré** : chaque échange avec les modèles d'IA passe par TLS (Transport Layer Security), comme le reste de l'application.
- **Un humain garde toujours le dernier mot** : aucune décision automatisée — chaque horaire, formation ou proposition générée par l'IA doit être revue et approuvée par un gestionnaire avant d'être appliquée (transparence exigée par la Loi 25 pour les traitements automatisés).
- **Garde-fous serveur** : chaque réponse de l'IA est validée par le serveur (employés existants, succursales permises, budgets, chevauchements) avant tout enregistrement — une réponse invalide est rejetée.

10. Lexique des acronymes et termes techniques

Loi 25	Loi québécoise modernisant la protection des renseignements personnels dans le secteur privé.
MFA	Multi-Factor Authentication — authentification multifacteur : un code en plus du mot de passe.
TOTP	Time-based One-Time Password — mot de passe à usage unique basé sur le temps (ex. Google Authenticator).
JWT	JSON Web Token — jeton de session signé qui expire automatiquement (24 h ici).
HTTPS / TLS	Transport Layer Security — chiffrement de toutes les communications entre l'appareil et le serveur.
AES / Fernet	Advanced Encryption Standard — norme de chiffrement utilisée pour protéger les fichiers sensibles.
SHA-256	Secure Hash Algorithm — fonction de hachage : transforme une donnée en empreinte irréversible.
bcrypt	Algorithme de hachage renforcé conçu spécifiquement pour protéger les mots de passe.
NIP	Numéro d'identification personnel — le code à 4 chiffres de la borne de pointage.
OPQ	Ordre des pharmaciens du Québec — ordre professionnel encadrant la pratique.
CAI	Commission d'accès à l'information du Québec — organisme de surveillance de la Loi 25.
ÉFVP	Évaluation des facteurs relatifs à la vie privée — analyse exigée avant un transfert de données hors Québec.
API	Application Programming Interface — interface de programmation permettant à deux logiciels de communiquer.
IA	Intelligence artificielle — ici, les modèles générant horaires et formations, toujours validés par un humain.
IP	Internet Protocol — l'adresse réseau identifiant un appareil connecté.
TCP	Transmission Control Protocol — protocole de connexion réseau utilisé pour les tests de balayage.

SIRH	Système d'information de ressources humaines — la catégorie de logiciel d'Arrière Plan.
UFW	Uncomplicated Firewall — pare-feu simplifié des serveurs Linux autonomes.

11. Résumé exécutif

Arrière Plan applique le principe de protection dès la conception (privacy by design) : consentement explicite, chiffrement des données sensibles, authentification forte imposable, journal d'audit exhaustif, droit à l'oubli en un clic et cloisonnement strict par pharmacie. Le code source est sécurisé et versionné sur GitHub (sans aucune donnée personnelle), et l'architecture permet une migration vers un hébergement entièrement québécois pour une conformité Loi 25 maximale.